

Analyse d'Impact relative à la Protection des Données (AIPD) – Projet d'analyse de données Alzheimer

Saisie :

Assmaa Abdelmoumni, Magali Cesarini, Bruce Vignolles

Évaluation :

Assmaa Abdelmoumni, Magali Cesarini, Bruce Vignolles

Validation :

Assmaa Abdelmoumni, Magali Cesarini, Bruce Vignolles

Statut :

Validation simple

100%

Validation

Cartographie des risques

Validation

Plan d'action

Principes fondamentaux

Aucun plan d'action enregistré.

Mesures existantes ou prévues

Aucun plan d'action enregistré.

Risques

Aucun plan d'action enregistré.

Validation

Avis du DPD et des personnes concernées

Nom du DPD

Bruce Vignolles, Assmaa Abdelmoumni, Magalie Cesarini

Statut du DPD

Le traitement pourrait être mis en oeuvre.

Opinion du DPD

Le traitement porte sur des données pseudonymisées issues de la base de recherche ADNI, utilisées dans un cadre strictement pédagogique. Les risques identifiés ont fait l'objet de mesures de sécurité adaptées (contrôle des accès, chiffrement, pseudonymisation, sauvegardes). Le niveau de risque résiduel est estimé moyen et maîtrisable. En conséquence, le traitement peut être mis en œuvre sous réserve du respect effectif des mesures préconisées dans la présente analyse.

Recherche de l'avis des personnes concernées

L'avis des personnes concernées a été demandé.

Noms des personnes concernées

Bruce Vignolles, Assmaa Abdelmoumni, Magalie Cesarini

Statuts des personnes concernées

Le traitement pourrait être mis en oeuvre.

Opinions des personnes concernées

Les participants de la base ADNI ont été consultés en amont par l'organisation ADNI lors de leur inclusion dans le programme de recherche. Leur consentement éclairé a été recueilli et couvre l'utilisation de leurs données à des fins de recherche scientifique. L'équipe projet intervenant en tant qu'utilisateur secondaire, aucune consultation directe supplémentaire n'a été réalisée, conformément aux conditions d'utilisation ADNI.

Contexte

Vue d'ensemble

Quel est le traitement qui fait l'objet de l'étude ?

Traitement : Analyse statistique, visualisation et modélisation prédictive de données relatives à la maladie d'Alzheimer.

Description : Le traitement consiste à exploiter un jeu de données médicales anonymisées provenant d'une base de recherche sur la maladie d'Alzheimer. Les données sont utilisées dans le cadre d'un projet pédagogique de formation Data Analyst afin de réaliser des analyses statistiques, des visualisations sous Power BI ainsi que des expérimentations de modèles de Machine Learning et de Deep Learning destinées à étudier les facteurs de risque et l'évolution cognitive des patients.

Finalité : Comprendre les caractéristiques de la cohorte étudiée, analyser les facteurs associés à l'évolution de la maladie d'Alzheimer et développer un prototype d'application de prédiction à des fins pédagogiques et de démonstration. Les résultats produits n'ont pas vocation à être utilisés pour établir un diagnostic médical ni à prendre des décisions concernant des personnes physiques.

Quelles sont les responsabilités liées au traitement ?

Responsable du traitement : Projet pédagogique réalisé dans le cadre de la formation Data Analyst de M2i Formation, sous la supervision du formateur référent.

Équipe projet : Trois étudiants en formation Data Analyst chargés de la préparation, du nettoyage, de l'analyse, de la modélisation et de la visualisation des données.

Formateur référent : Assure la supervision méthodologique du projet, l'accompagnement pédagogique des étudiants, la validation des travaux réalisés et le respect des bonnes pratiques relatives à la protection des données.

Destinataires des résultats : Équipe pédagogique de M2i Formation, formateur référent et jury de soutenance dans le cadre de l'évaluation du projet de formation.

Quels sont les référentiels applicables ?

Le traitement est réalisé en tenant compte des référentiels suivants :

- Règlement Général sur la Protection des Données (RGPD) – Règlement (UE) 2016/679.
- Loi Informatique et Libertés modifiée.
- Recommandations et guides de la CNIL relatifs à la protection des données personnelles.
- Recommandations de la CNIL concernant le traitement des données de santé et les analyses d'impact relatives à la protection des données (AIPD).
- Principes de protection des données dès la conception et par défaut (Privacy by Design et Privacy by Default).
- Bonnes pratiques de sécurité, de confidentialité et d'anonymisation des données.
- Cadre pédagogique de la formation Data Analyst de M2i Formation.

Évaluation : Acceptable

Commentaire d'évaluation :

L'analyse d'impact sur la vie privée (PIA) relative aux données ADNI démontre une prise en compte adéquate des risques liés au traitement de données de santé et à la réidentification indirecte des participants. Les mesures mises en œuvre — notamment la pseudonymisation, le contrôle d'accès restreint, le chiffrement des données, et la traçabilité des opérations — permettent de réduire efficacement la probabilité et la gravité des risques identifiés. Les procédures de conformité au RGPD sont bien intégrées : les finalités du traitement sont clairement définies, les durées de conservation limitées, et les droits des personnes (accès, rectification, suppression) sont garantis. En conséquence, le niveau de risque résiduel est jugé faible à modéré, et le PIA peut être validé sous réserve du maintien des mesures de sécurité et de gouvernance prévues.

Contexte

Données, processus et supports

Quelles sont les données traitées ?

Le traitement porte sur des données issues de la base de recherche ADNI (Alzheimer's Disease Neuroimaging Initiative). Les catégories de données exploitées dans le cadre du projet sont les suivantes :

- Données démographiques : âge, sexe, niveau d'éducation
- Données diagnostiques : diagnostic clinique et statut cognitif des participants (DIAGNOSIS).
- Données cognitives et neuropsychologiques : scores MMSE, ADAS, CDR, et autres évaluations permettant de mesurer les fonctions cognitives.

- Antécédents médicaux et facteurs de risque : variables relatives aux antécédents neurologiques, psychiatriques, à la consommation d'alcool, de tabac et autres facteurs de risque disponibles dans le jeu de données.
- Données biomédicales : variables cliniques et biologiques disponibles dans les tables ADNI utilisées pour l'analyse statistique.
- Données d'imagerie médicale : images IRM cérébrales utilisées dans le cadre des expérimentations de Deep Learning depuis un jeu de données disponible sur Kaggle

Les données analysées sont pseudonymisées et identifiées par un identifiant de recherche (RID). Aucune donnée directement identifiante telle que le nom, le prénom, l'adresse postale, l'adresse électronique ou le numéro de téléphone n'est utilisée dans le projet.

Comment le cycle de vie des données se déroule-t-il (description fonctionnelle) ?

1. Collecte des données

Le projet utilise deux sources de données distinctes. Les données cliniques et cognitives sont issues de la base de recherche ADNI (Alzheimer's Disease Neuroimaging Initiative) sous forme de fichiers CSV pseudonymisés. Les images IRM utilisées pour les expérimentations de Deep Learning proviennent d'un jeu de données public disponible sur la plateforme Kaggle. Aucune collecte directe auprès des personnes concernées n'est réalisée.

2. Ingestion des données

Les données sont importées et intégrées à l'aide de KNIME. Les fichiers sources sont contrôlés, structurés et chargés dans l'environnement de stockage du projet.

3. Stockage des données

Les données brutes sont stockées dans une zone Data Lake hébergée sur Supabase (région Union Européenne). Les données préparées et structurées sont ensuite intégrées dans un Data Warehouse PostgreSQL afin de faciliter les analyses décisionnelles. Les images IRM sont conservées localement sur les postes de travail des membres de l'équipe projet.

4. Préparation et transformation

Les opérations d'exploration des données (EDA), de nettoyage, de transformation, de gestion des valeurs manquantes et de préparation des variables sont réalisées à l'aide de Python. Les données sont ensuite organisées selon une architecture décisionnelle adaptée aux analyses.

5. Analyse et modélisation

Les données préparées sont exploitées à l'aide de SQL, Python et Power BI afin de réaliser des analyses statistiques, d'étudier les facteurs de risque associés à la maladie d'Alzheimer et de produire des tableaux de bord interactifs. Des modèles de Machine Learning et de Deep Learning sont également développés à des fins pédagogiques pour explorer les mécanismes de prédiction liés à l'évolution de la maladie.

6. Restitution des résultats

Les résultats sont présentés sous forme de rapports, d'analyses, de visualisations Power BI et de démonstrations pédagogiques destinés aux membres de l'équipe projet, au formateur référent, à l'équipe pédagogique et au jury de soutenance.

7. Conservation et fin de traitement

Les données sont conservées pendant toute la durée nécessaire à la réalisation du projet pédagogique. À l'issue du projet, les données et copies de travail sont archivées ou supprimées conformément aux

consignes de la formation et aux bonnes pratiques de gestion des données.

Quels sont les supports des données ?

Les données du projet sont stockées, traitées ou consultées sur les supports suivants :

- Base de données PostgreSQL hébergée sur Supabase (région Union Européenne).
- Zone Data Lake contenant les données brutes importées depuis les différentes sources.
- Zone Data Warehouse contenant les données nettoyées, transformées et modélisées selon une architecture décisionnelle.
- Postes de travail des membres de l'équipe projet utilisés pour les traitements Python, SQL, Power BI et Deep Learning.
- Fichiers CSV issus de la base de recherche ADNI.
- Images IRM stockées localement sur les postes de travail des membres de l'équipe projet.
- Logiciel KNIME utilisé pour l'ingestion et les flux de traitement des données.
- Environnement Python utilisé pour l'exploration des données (EDA), le nettoyage et les analyses statistiques.
- Power BI Desktop utilisé pour la visualisation et la restitution des résultats.
- Réseau Internet sécurisé permettant les échanges entre les postes de travail et la plateforme Supabase.

Évaluation : Acceptable

Commentaire d'évaluation :

Le traitement apparaît globalement conforme aux principes de nécessité, de proportionnalité et de minimisation des données, sous réserve de la mise en œuvre effective des mesures de sécurité adaptées à la sensibilité des informations traitées.

Niveau de risque initial : Élevé, en raison de la présence de données de santé, d'imagerie médicale et de traitements analytiques avancés.

Niveau de risque résiduel estimé : Moyen, sous réserve :

- du maintien de la pseudonymisation ;
- de la sécurisation des postes de travail ;
- du contrôle des accès aux données ;
- de la formalisation des procédures de conservation et de suppression.

Favorable avec réserves.

Les informations fournies dans ces trois rubriques sont satisfaisantes et démontrent une bonne maîtrise fonctionnelle du traitement. Néanmoins, des compléments relatifs aux mesures de sécurité opérationnelles, aux habilitations et aux modalités de conservation devront être documentés afin de consolider l'analyse d'impact et de réduire les risques résiduels identifiés.

Principes fondamentaux

Proportionnalité et nécessité

Les finalités du traitement sont-elles déterminées, explicites et légitimes ?

Oui. Le traitement des données a pour finalité l'analyse et l'étude de la maladie d'Alzheimer dans un cadre scientifique et de recherche médicale.

Les données issues de la base ADNI (Alzheimer's Disease Neuroimaging Initiative) sont utilisées afin de :

- étudier l'évolution de la maladie d'Alzheimer ;
- analyser les biomarqueurs et données cliniques associés ;
- développer et évaluer des modèles d'analyse et d'aide au diagnostic ;
- améliorer la compréhension scientifique des maladies neurodégénératives ;
- produire des rapports de recherche et des résultats statistiques.

Ces finalités sont clairement définies, limitées à des objectifs de recherche scientifique et conformes aux exigences du RGPD concernant les traitements de données de santé.

Évaluation : Acceptable

Commentaire d'évaluation :

Les finalités du traitement sont clairement définies, explicites et cohérentes avec la nature des données exploitées. Les objectifs poursuivis relèvent exclusivement de la recherche scientifique, de l'analyse statistique et de l'expérimentation pédagogique autour de la maladie d'Alzheimer. Les traitements envisagés apparaissent légitimes, proportionnés et conformes au principe de limitation des finalités prévu par le RGPD. Aucun détournement de finalité n'est identifié à ce stade. L'évaluation est donc considérée comme acceptable.

Quel(s) est(sont) les fondement(s) qui rend(ent) votre traitement licite ?

Le traitement repose sur :

- l'intérêt public dans le domaine de la recherche scientifique et médicale ;
- l'article 9 du RGPD autorisant le traitement de données de santé à des fins de recherche scientifique ;
- les autorisations et conditions d'utilisation prévues par la plateforme ADNI ;
- le consentement initial recueilli par ADNI auprès des participants à l'étude.

Les données utilisées sont des données sensibles de santé nécessitant des garanties renforcées de sécurité, confidentialité et limitation d'accès.

Évaluation : Acceptable

Commentaire d'évaluation :

Le traitement repose sur des fondements juridiques identifiés et documentés. Les données proviennent de la base de recherche ADNI, mise à disposition dans un cadre scientifique et de recherche médicale. Les conditions d'utilisation de la plateforme ainsi que le consentement initial recueilli auprès des participants constituent des garanties complémentaires. Les données traitées étant des données de santé, des mesures renforcées de sécurité, de confidentialité et de contrôle des accès sont mises en œuvre afin d'assurer la conformité au RGPD. Les fondements du traitement apparaissent cohérents avec les finalités poursuivies.

Les données collectées sont-elles adéquates, pertinentes et limitées à ce qui est nécessaire au regard des finalités pour lesquelles elles sont traitées (minimisation des données) ?

Oui. Seules les données strictement nécessaires aux objectifs scientifiques du projet sont utilisées.

Les données exploitées peuvent inclure :

- données démographiques ;
- informations cliniques ;
- résultats d'examens cognitifs ;
- données d'imagerie médicale ;
- biomarqueurs liés à la maladie d'Alzheimer.

Les traitements sont limités aux variables nécessaires à l'analyse. Aucune donnée non pertinente n'est collectée ou utilisée.

Lorsque cela est possible, les données sont pseudonymisées afin de réduire les risques d'identification des personnes concernées.

Évaluation : Acceptable

Commentaire d'évaluation :

Les catégories de données utilisées ont été sélectionnées en fonction de leur utilité pour les objectifs scientifiques du projet. Seules les données nécessaires à l'analyse de la maladie d'Alzheimer et à l'étude des facteurs associés sont traitées. Les variables non pertinentes pour les finalités poursuivies sont exclues des traitements. Les données sont pseudonymisées afin de limiter les risques d'identification des personnes concernées. Le principe de minimisation des données est considéré comme respecté.

Les données sont-elles exactes et tenues à jour ?

Les données proviennent directement de la plateforme ADNI, reconnue comme source de référence scientifique dans le domaine de la recherche sur Alzheimer.

Des mesures sont mises en place afin de garantir :

- l'intégrité des données importées ;
- la vérification des jeux de données utilisés ;
- la traçabilité des traitements réalisés ;
- la mise à jour des données lorsque de nouvelles versions sont disponibles ;
- la suppression des données incorrectes ou corrompues.

Les résultats produits reposent sur des données validées et maintenues par le consortium ADNI.

Évaluation : Acceptable

Commentaire d'évaluation :

Ces dispositions permettent de limiter les risques d'utilisation de données inexactes ou obsolètes et contribuent à la fiabilité des analyses statistiques et des modèles développés dans le cadre du projet.

Toutefois, les modalités concrètes de contrôle qualité, de validation des mises à jour et de gestion des

anomalies pourraient être davantage détaillées afin de renforcer la démonstration de conformité. Cette réserve n'est cependant pas de nature à remettre en cause l'adéquation globale des mesures présentées.

Les mécanismes décrits apparaissent adaptés à la nature du projet et permettent de considérer que le principe d'exactitude et de mise à jour des données est globalement respecté. L'évaluation est donc jugée acceptable.

Quelle est la durée de conservation des données ?

Les données sont conservées uniquement pendant la durée nécessaire aux travaux de recherche et conformément aux conditions d'utilisation définies par ADNI ainsi qu'aux exigences réglementaires applicables.

À l'issue du projet, les données sont supprimées, archivées de manière sécurisée ou anonymisées lorsque cela est possible.

Évaluation : Acceptable

Commentaire d'évaluation :

Les données ADNI sont conservées uniquement pendant la durée nécessaire à la réalisation du projet pédagogique, soit jusqu'à la soutenance. Conformément aux conditions d'utilisation ADNI et aux exigences du RGPD, à l'issue du projet :

- Les fichiers CSV et datasets traités sont supprimés des postes de travail locaux
- Les données stockées sur Supabase sont supprimées
- Le code source est conservé sur GitHub à des fins pédagogiques, sans données personnelles
- Les images IRM stockées localement sont supprimées après la soutenance

Évaluation est donc jugée acceptable

Principes fondamentaux

Mesures protectrices des droits

Comment les personnes concernées sont-elles informées à propos du traitement ?

Les participants de la base ADNI ont été informés du traitement de leurs données lors de leur inclusion dans le programme de recherche, via un formulaire de consentement éclairé signé. Dans le cadre de ce projet d'analyse, les données sont utilisées conformément aux conditions d'accès définies par l'ADNI. Aucune information directement identifiante n'est traitée par l'équipe projet.

Évaluation : Acceptable

Commentaire d'évaluation :

Les personnes concernées ont été informées lors de leur participation à l'étude ADNI des modalités de collecte et d'utilisation de leurs données dans un cadre de recherche scientifique. L'utilisation des données par l'équipe projet s'effectue dans le respect des conditions d'accès et d'utilisation définies par ADNI. Les données exploitées ne comportent pas d'éléments directement identifiants permettant d'identifier les participants. Le niveau d'information des personnes concernées est considéré comme compatible avec la

finalité de recherche poursuivie.

Si applicable, comment le consentement des personnes concernées est-il obtenu ?

Cette question n'est pas directement applicable dans le cadre de ce projet. Les données ADNI ont été collectées avec le consentement éclairé des participants par l'organisation ADNI. Notre équipe accède aux données en tant qu'utilisateurs secondaires, dans le cadre strict des conditions d'utilisation ADNI, sans interaction directe avec les participants. Aucun nouveau consentement n'est donc recueilli par l'équipe projet.

Évaluation : Acceptable

Commentaire d'évaluation :

Les modalités présentées concernant le consentement sont cohérentes avec la nature du projet et le cadre juridique applicable. Les données étant issues de la base ADNI, le consentement des participants a été recueilli en amont par l'organisation responsable du traitement originel, dans le respect des exigences éthiques et réglementaires en vigueur. L'équipe projet intervient en tant qu'utilisateur secondaire des données, sans interaction directe avec les personnes concernées.

Cette organisation est compatible avec le RGPD dans le cadre d'un traitement à des fins de recherche scientifique, dès lors que le consentement initial couvre l'utilisation des données pour ce type de projet. Aucun nouveau consentement n'étant requis, la question du recueil direct ne se pose pas pour l'équipe projet.

Les dispositions présentées sont adaptées au contexte et permettent de considérer que la base légale du traitement est correctement justifiée. L'évaluation est jugée acceptable.

Comment les personnes concernées peuvent-elles exercer leurs droit d'accès et droit à la portabilité ?

Les participants peuvent exercer leur droit d'accès et de portabilité directement auprès de l'ADNI (adni.loni.usc.edu), organisation responsable du traitement originel des données. Dans le cadre du projet, les données étant pseudonymisées, il n'est pas possible d'identifier un participant à partir du RID seul.

Évaluation : Acceptable

Commentaire d'évaluation :

Les modalités présentées sont cohérentes avec la nature des données utilisées dans le projet. Les données étant issues de la base ADNI et traitées sous forme pseudonymisée, les droits d'accès et de portabilité relèvent principalement du responsable du traitement d'origine. Le projet ne dispose pas des éléments permettant d'identifier directement les personnes concernées à partir des identifiants de recherche utilisés, ce qui limite sa capacité à répondre directement à de telles demandes.

Cette organisation est compatible avec le principe de protection des données, dès lors que les personnes concernées peuvent exercer leurs droits auprès de l'organisme source ayant collecté les données et conservant les informations d'identification nécessaires. Aucun risque particulier de non-respect des droits d'accès ou de portabilité n'est identifié dans le cadre du traitement décrit.

Les dispositions présentées sont adaptées au contexte du projet et permettent de considérer que l'exercice des droits d'accès et de portabilité est correctement pris en compte. L'évaluation est jugée acceptable.

Comment les personnes concernées peuvent-elles exercer leurs droit de rectification et droit à l'effacement (droit à l'oubli) ?

Les participants peuvent exercer leur droit d'accès et de portabilité directement auprès de l'ADNI (adni.loni.usc.edu), organisation responsable du traitement originel des données. Dans le cadre du projet, les données étant pseudonymisées, il n'est pas possible d'identifier un participant à partir du RID seul.

Évaluation : Acceptable

Commentaire d'évaluation :

Les droits des personnes concernées sont exercés auprès du responsable du traitement initial, à savoir ADNI, qui conserve les informations nécessaires à l'identification des participants et à la gestion de leurs droits. L'équipe projet ne dispose pas des éléments permettant d'identifier directement les personnes concernées et ne peut donc pas traiter directement les demandes de rectification ou d'effacement. Les données utilisées sont pseudonymisées et exploitées dans un cadre de recherche conforme aux conditions d'utilisation définies par ADNI.

Comment les personnes concernées peuvent-elles exercer leurs droit de limitation et droit d'opposition ?

Les participants souhaitant limiter ou s'opposer au traitement de leurs données doivent contacter directement l'ADNI, responsable du traitement originel. L'équipe projet s'engage à appliquer toute restriction notifiée par l'ADNI et à exclure immédiatement les données concernées de toutes les analyses en cours

Évaluation : Acceptable

Commentaire d'évaluation :

Les modalités décrites prennent en compte les droits de limitation du traitement et d'opposition des personnes concernées conformément aux principes du RGPD. Le document précise que les demandes doivent être adressées à l'organisme responsable de la collecte initiale des données (ADNI), seul en mesure d'identifier les participants et de gérer leurs droits de manière effective.

L'équipe projet indique qu'elle s'engage à appliquer toute restriction de traitement ou opposition notifiée par ADNI et à exclure sans délai les données concernées des analyses en cours. Cette organisation est cohérente avec l'utilisation de données pseudonymisées et avec le rôle du projet, qui ne dispose pas des informations nécessaires pour identifier directement les personnes concernées.

Toutefois, il serait pertinent de formaliser davantage la procédure de prise en compte de ces demandes, notamment les modalités de réception des notifications d'ADNI, les délais de mise en œuvre et les actions réalisées sur les données déjà intégrées dans les environnements de travail.

Les dispositions prévues permettent d'assurer le respect des droits de limitation et d'opposition dans le contexte du projet. La responsabilité de gestion des demandes est correctement attribuée au responsable du traitement d'origine, tandis que l'équipe projet prévoit les mesures nécessaires pour appliquer les restrictions communiquées. L'évaluation est donc considérée comme acceptable.

Les obligations des sous-traitants sont-elles clairement définies et contractualisées ?

Les outils utilisés dans le cadre du projet sont Jupyter Notebook(traitement et analyse), Supabase (stockage des données), et GitHub (versioning du code). Ces plateformes interviennent en tant que sous-

traitants techniques et sont soumises à leurs conditions générales d'utilisation respectives, qui incluent des engagements en matière de protection des données. Les données stockées sont pseudonymisées. Aucune donnée n'est partagée avec des tiers non autorisés en dehors de ces outils.

Évaluation : Acceptable

Commentaire d'évaluation :

Les obligations des sous-traitants sont clairement identifiées et adaptées au contexte du projet. Les trois plateformes utilisées (Jupyter Notebook, Supabase et GitHub) sont correctement qualifiées de sous-traitants techniques. Leurs engagements en matière de protection des données sont encadrés par leurs conditions générales d'utilisation respectives, ce qui constitue une base contractuelle suffisante dans le cadre d'un projet pédagogique.

La pseudonymisation des données stockées et l'absence de partage avec des tiers non autorisés renforcent la conformité du traitement. Les mesures mises en œuvre sont proportionnées à la sensibilité des données et au contexte académique du projet.

Les dispositions présentées sont jugées suffisantes pour répondre aux exigences de protection des données applicables. L'évaluation est jugée acceptable.

En cas de transfert de données en dehors de l'Union européenne, les données sont-elles protégées de manière équivalente ?

Les outils utilisés (Jupyter Notebook, GitHub, Supabase) sont hébergés sur des serveurs situés aux États-Unis, ce qui constitue un transfert hors UE. Ces transferts sont encadrés par les Clauses Contractuelles Types (CCT) adoptées par la Commission européenne, auxquelles ces fournisseurs sont soumis. Par ailleurs, les données transférées sont pseudonymisées, ce qui limite significativement le risque en cas d'incident de sécurité.

Évaluation : Acceptable

Commentaire d'évaluation :

Aucun transfert systématique de données personnelles vers un pays tiers n'a été identifié dans le cadre du stockage principal des données, celles-ci étant hébergées dans l'Union européenne. Les éventuels services fournis par des entreprises situées hors UE sont encadrés par les garanties prévues par le RGPD. Les données utilisées sont pseudonymisées, ce qui réduit davantage les risques pour les personnes concernées. L'évaluation est jugée acceptable

Risques

Mesures existantes ou prévues

Accès non autorisé aux données de santé

- Authentification sécurisée des utilisateurs ;
- Restriction des accès aux seules personnes habilitées ;
- Gestion des droits d'accès ;
- Journalisation des accès ;
- Sensibilisation des utilisateurs aux règles de confidentialité.

Évaluation : Acceptable

Commentaire d'évaluation :

Des mesures techniques et organisationnelles ont été mises en œuvre afin de limiter les risques d'accès non autorisé aux données de santé. Les accès sont réservés aux seules personnes habilitées selon le principe du moindre privilège. L'authentification des utilisateurs, la gestion des droits d'accès, la journalisation des actions et la sensibilisation aux règles de confidentialité contribuent à réduire significativement la probabilité de survenue du risque. Le risque résiduel est considéré comme faible à modéré et acceptable au regard des mesures de protection déployées.

Réidentification indirecte des participants

- Utilisation de données pseudonymisées provenant d'ADNI ;
- Absence d'identifiants directs ;
- Limitation des variables exploitées ;
- Contrôle des exports et partages de données ;
- Accès limité aux données complètes.

Évaluation : Acceptable

Commentaire d'évaluation :

Ces dispositions contribuent à réduire significativement le risque d'identification d'une personne à partir des données traitées. Toutefois, compte tenu de la présence de données de santé et d'imagerie médicale, un risque résiduel de réidentification indirecte demeure théoriquement possible par croisement de plusieurs variables. Il est donc recommandé de maintenir une politique stricte de gestion des habilitations, de contrôle des exports et de sensibilisation des utilisateurs aux exigences de confidentialité.

Les mesures décrites sont pertinentes et proportionnées au risque identifié. La pseudonymisation des données, associée à la limitation des accès et au contrôle des traitements, permet de réduire efficacement le risque de réidentification indirecte des participants. Le niveau de risque résiduel apparaît maîtrisé dans le contexte du projet. L'évaluation est donc considérée comme acceptable

Perte ou altération des données

- Mesures existantes ou prévues
- Sauvegardes régulières ;
- Stockage sécurisé ;
- Contrôles d'intégrité des données ;
- Protection antivirus et surveillance des systèmes ;
- Procédures de restauration des données.

Évaluation : Acceptable

Commentaire d'évaluation :

Les mesures identifiées pour traiter le risque de perte ou d'altération des données sont cohérentes et adaptées au contexte du projet. Les sauvegardes régulières, le stockage sécurisé sur Supabase et les procédures de restauration constituent un dispositif proportionné à la sensibilité des données traitées. Le versioning du code sur GitHub permet également de limiter le risque de perte accidentelle lors des phases de traitement et d'analyse.

Les contrôles d'intégrité et la surveillance des systèmes renforcent la capacité de détection et de correction en cas d'incident. L'ensemble de ces mesures démontre une prise en compte sérieuse de ce risque.

Les dispositions présentées sont jugées suffisantes pour répondre aux exigences de protection des données applicables. L'évaluation est jugée acceptable.

Utilisation des données hors du cadre prévu

- Mesures existantes ou prévues
- Définition claire des finalités du traitement ;
- Respect des conditions d'utilisation d'ADNI ;
- Encadrement des accès aux données ;
- Sensibilisation des utilisateurs aux obligations RGPD.

Évaluation : Acceptable

Commentaire d'évaluation :

Les finalités du traitement sont clairement définies et documentées. L'utilisation des données est limitée aux objectifs du projet et aux conditions d'utilisation fixées par ADNI. Les accès aux données sont restreints aux personnes autorisées et les utilisateurs sont sensibilisés aux obligations légales et réglementaires applicables, notamment celles relatives au RGPD. Ces mesures permettent de réduire significativement le risque d'utilisation des données à des fins non prévues. Le risque résiduel est considéré comme faible et acceptable.

Transmission non sécurisée des données

- Utilisation de connexions sécurisées ;
- Chiffrement des transferts ;
- Limitation des échanges de données ;
- Contrôle des supports de stockage.

Évaluation : Acceptable

Commentaire d'évaluation :

Les mesures identifiées pour traiter le risque de transmission non sécurisée sont adaptées au contexte du projet. L'utilisation de connexions sécurisées HTTPS/TLS entre les outils (Supabase, Jupyter Notebook, GitHub) garantit le chiffrement des données en transit. La limitation des échanges de données et le contrôle des supports de stockage réduisent significativement la surface d'exposition au risque.

Les données transmises étant pseudonymisées, le risque résiduel en cas d'interception reste limité. L'ensemble de ces mesures démontre une prise en compte appropriée des exigences de sécurité pour les transferts de données.

Les dispositions présentées sont jugées suffisantes pour répondre aux exigences de protection des données applicables. L'évaluation est jugée acceptable.

Risques

Accès illégitime à des données

Quels pourraient être les principaux impacts sur les personnes concernées si le risque se produisait ?

Violation de la confidentialité des données de santé des participants, Divulgence d'informations médicales sensibles (diagnostic, données cognitives, imagerie cérébrale)., Atteinte à la vie privée et risque de stigmatisation des personnes concernées.

Quelles sont les principales menaces qui pourraient permettre la réalisation du risque ?

Accès non autorisé par un membre externe à l'équipe projet, Compromission d'un compte utilisateur (mot de passe faible ou volé), Fuite via un outil tiers mal sécurisé (Supabase, Jupyter Notebook, GitHub), Partage accidentel d'un fichier ou d'un lien d'accès.

Quelles sources de risques pourraient-elles en être à l'origine ?

Acteur externe malveillant (cyberattaque, phishing), Erreur humaine interne (mauvaise gestion des droits d'accès)., Défaillance d'un sous-traitant (faille de sécurité chez Microsoft, GitHub ou Supabase).

Quelles sont les mesures initiales, parmi celles identifiées, qui contribuent à traiter le risque ?

Accès non autorisé aux données de santé, Réidentification indirecte des participants, Transmission non sécurisée des données, Perte ou altération des données, Utilisation des données hors du cadre prévu

Comment estimez-vous la gravité du risque, notamment en fonction des impacts potentiels et des mesures prévues ?

Importante, Les données de santé sont des données sensibles au sens du RGPD. Un accès illégitime aurait un impact significatif sur la vie privée des participants, même si les données sont pseudonymisées.

Comment estimez-vous la vraisemblance du risque, notamment au regard des menaces, des sources de risques et des mesures prévues ?

Limitée, Les données sont pseudonymisées, les accès sont restreints à l'équipe projet, et les outils utilisés (GitHub, Supabase, Jupyter) disposent de mécanismes de sécurité robustes.

Évaluation : Acceptable

Commentaire d'évaluation :

L'analyse met en évidence un risque intrinsèque élevé en raison de la sensibilité des données de santé traitées. Toutefois, les menaces et sources de risques ont été correctement identifiées et plusieurs mesures de protection adaptées sont déjà en place. La combinaison de la pseudonymisation, de la limitation des accès et du contrôle des traitements permet de réduire significativement l'exposition au risque.

Gravité : Importante

Vraisemblance : Limitée

Niveau de risque résiduel : Moyen et maîtrisé, sous réserve du maintien des mesures de sécurité et du contrôle continu des accès aux données.

Risques

Modification non désirées de données

Quels pourraient être les principaux impacts sur les personnes concernées si le risque se produisait ?

Atteinte à la confidentialité des données de santé, Risque de réidentification indirecte des participants, Divulgence d'informations médicales sensibles, Atteinte à la vie privée des personnes concernées, Utilisation non autorisée des données de recherche, Perte de confiance des participants envers les projets scientifiques et médicaux

Quelles sont les principales menaces qui pourraient permettre la réalisation du risque ?

Accès non autorisé aux données, Mauvaise gestion des droits d'accès, Erreur humaine lors du traitement ou du partage des données, Cyberattaque ou intrusion informatique, Transmission non sécurisée des fichiers, Utilisation abusive des données par un utilisateur autorisé.

Quelles sources de risques pourraient-elles en être à l'origine ?

Utilisateurs internes, Défaut de sécurisation des systèmes informatiques, Logiciels malveillants, Mauvaises pratiques de gestion des données, Supports de stockage non sécurisés, Vulnérabilités techniques des infrastructures utilisées

Quelles sont les mesures, parmi celles identifiées, qui contribuent à traiter le risque ?

Accès non autorisé aux données de santé, Réidentification indirecte des participants, Perte ou altération des données, Utilisation des données hors du cadre prévu, Transmission non sécurisée des données

Comment estimez-vous la gravité du risque, notamment en fonction des impacts potentiels et des mesures prévues ?

Limitée, Les données traitées concernent des informations de santé sensibles relatives à la maladie d'Alzheimer. Toutefois, les données utilisées sont pseudonymisées et ne contiennent pas d'identifiants directs tels que les noms ou prénoms des participants. Les mesures de sécurité mises en œuvre permettent de réduire significativement les impacts potentiels sur les personnes concernées.

Comment estimez-vous la vraisemblance du risque, notamment au regard des menaces, des sources de risques et des mesures prévues ?

Limitée, Le risque de réidentification ou d'accès non autorisé reste faible grâce à l'utilisation de données pseudonymisées issues d'ADNI, aux restrictions d'accès mises en place et aux mesures de sécurité techniques et organisationnelles appliquées au projet.

Évaluation : Acceptable

Risques

Disparition de données

Quels pourraient être les principaux impacts sur les personnes concernées si le risque se produisait ?

Perte des données de recherche rendant impossible toute analyse ultérieure. Interruption du projet et perte des résultats scientifiques obtenus. Nécessité de re-télécharger et re-traiter les données depuis l'ADNI, avec un risque de non-disponibilité.

Quelles sont les principales menaces qui pourraient permettre la réalisation du risque ?

Suppression accidentelle d'un fichier CSV ou du dataset mergé lors du preprocessing. Écrasement involontaire du notebook ou des données traitées. Défaillance technique d'un outil de stockage (Supabase, Jupyter). Expiration ou suspension d'un compte sur une plateforme tierce.

Quelles sources de risques pourraient-elles en être à l'origine ?

Erreur humaine lors des manipulations de données dans le notebook. Défaillance d'un sous-traitant technique (panne Supabase, jupyter). Suppression accidentelle du dépôt GitHub ou des branches de travail.

Quelles sont les mesures, parmi celles identifiées, qui contribuent à traiter le risque ?

Perte ou altération des données

Comment estimez-vous la gravité du risque, notamment en fonction des impacts potentiels et des mesures prévues ?

Limitée,

La disparition des données n'impacte pas directement la vie privée des participants puisque les données sont pseudonymisées et restent disponibles auprès de l'ADNI. L'impact est principalement sur la continuité du projet.

Comment estimez-vous la vraisemblance du risque, notamment au regard des menaces, des sources de risques et des mesures prévues ?

Limitée, Les données sont versionnées sur GitHub, stockées sur Supabase, et le dataset source reste accessible via l'ADNI. Le risque de perte définitive est donc faible.

Évaluation : Acceptable

Risques

Vue d'ensemble des risques